



SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

Lima, 31 de agosto de 2022

OFICIO N° 36482-2022-SBS

Señor
Gerente General
Gerencia Mancomunada
Presente.-

Me dirijo a usted con relación al Oficio N° 20887-2022-SBS, de fecha 23 de mayo del presente, mediante el cual se le solicitó a su representada realizar, con carácter de urgencia, una evaluación del impacto generado por la presunta filtración de datos personales contenidos en el Registro Nacional de Identidad; asimismo, al incremento en la casuística de operaciones fraudulentas asociadas a *SIM Swapping*¹ y *Phishing*².

Sobre el particular, sírvase tomar conocimiento de las instrucciones relevantes vinculadas al Reglamento para la Gestión de la Seguridad de la Información y la Ciberseguridad, aprobado por Resolución SBS N° 504-2021 y modificatorias, indicadas en el Anexo 1 adjunto al presente oficio, y disponga las medidas inmediatas que corresponda.

Asimismo, a fin de evidenciar que su representada ha implementado medidas de seguridad conforme al numeral 5 del artículo 12 del Reglamento, remita a esta Superintendencia los resultados de una evaluación independiente sobre la seguridad de las aplicaciones, web y móviles, las que deben ser efectuadas conforme a los estándares de verificación de seguridad ASVS³ y MASVS⁴, respectivamente.

Al respecto, dichas evaluaciones deben ser presentadas como máximo hasta el 31 de diciembre de 2022, con alcance en las aplicaciones que se encuentren en ambiente productivo al 31 de octubre de 2022.

¹ SIM Swapping, procedimiento de cambio de chip que se efectúa ante el operador de telefonía móvil que, obtenido mediante suplantación del titular, puede dar a lugar a operaciones fraudulentas en servicios financieros, mediante la vulneración del factor de autenticación en posesión del usuario (dispositivo móvil).

² Phishing, modalidad de ciber ataque que busca hacer que la víctima revele datos personales a través de páginas web que fingen ser sitios legítimos.

³ Application Security Verification Standard (ASVS) es un estándar de verificación de seguridad para aplicaciones web, publicado por el Open Web Application Security Project, Owasp; disponible en <https://owasp.org/www-project-application-security-verification-standard/>

⁴ Mobile Application Security Verification Standard (MASVS) es un estándar de verificación de seguridad de aplicaciones móviles, publicado por el Open Web Application Security Project, Owasp; disponible en <https://github.com/OWASP/owasp-masvs/releases/tag/v1.4.2>





SUPERINTENDENCIA

DE BANCA, SEGUROS Y AFP

República del Perú

Finalmente, se requiere que su representada remita, en un plazo de 30 día calendarios de recibido el presente oficio, la información indicada en el Anexo 2 sobre aplicaciones web y móviles en producción a través de las cuales se realice alguna acción que requiera autenticación reforzada.

Atentamente,

JORGE DAMASO MOGROVEJO GONZALEZ
SUPERINTENDENTE ADJUNTO DE BANCA Y MICROFINANZAS

MCM/ccc

Los Laureles N° 214 - Lima 27 - Perú Telf.: (511) 6309000 Fax: (511) 6309239





SUPERINTENDENCIA

DE BANCA, SEGUROS Y AFP

República del Perú

Anexo 1. Instrucciones sobre aplicación de la Resolución SBS N° 504-2022

1. Art. 2, literal j; Art. 18 y Art. 19. El registro por primera vez o el cambio de los factores de posesión (ejemplo, dispositivo móvil) o conocimiento (ejemplo, contraseña), que solo posee el usuario o que solo conoce el usuario, constituyen acciones con posible perjuicio al usuario al efectuarse por canal digital, por lo que requiere previa verificación de dos factores válidos.
2. Art. 2, literal j y Art. 19. El uso de preguntas de reto como factor que conoce solo el usuario, para fines de autenticación reforzada, requiere que sea el usuario quien las establezca, además de que cuando se almacena o transfiere sea de forma cifrada.
3. Art. 2, literal j. El uso del teléfono móvil como factor que solo posee el usuario, cuya posesión es probada mediante el envío de OTP vía SMS a dicho teléfono móvil, no constituye un factor válido, por su vulnerabilidad a suplantación vía SIM Swapping y la ausencia de condiciones técnicas que aseguren la confidencialidad de la transmisión de los mensajes SMS⁵.
4. Art. 2, literal j. El uso del teléfono móvil con una aplicación móvil instalada, como factor que solo posee el usuario, cuya posesión es probada mediante el uso de una OTP recibida en dicha aplicación móvil, no constituye un factor válido, a menos que dicho uso esté condicionado a que la aplicación verifique que el dispositivo móvil corresponde a aquel afiliado por el usuario al momento del enrolamiento.
5. Art. 2, literal j. La firma manuscrita registrada en un voucher o a través de una pantalla táctil no constituye un factor de autenticación de inherencia⁶, salvo que medie una validación de dicho factor que sea resistente a amenazas de suplantación, con un alto ratio de éxito⁷, contra un registro oficial o previamente constituido por la empresa.
6. Art. 2, literal j. La biométrica cuya validación es efectuada por los teléfonos y otros dispositivos móviles no constituyen factor de autenticación de inherencia⁶, salvo que dicha validación sea resistente a amenazas de suplantación, con un alto ratio de éxito⁷, contra un registro oficial o previamente constituido por la empresa.
7. Art. 2, literal j. La posesión de una tarjeta de crédito o débito, así como la información contenida en ellas, como factor que solo posee el usuario, constituye un único factor de autenticación.

⁵ SMS, Short Message Service, servicio de mensajería de textos disponible a través de los servicios de telecomunicaciones.

⁶ Factor de inherencia, corresponde a algo que el usuario es

⁷ Tomando en cuenta las recomendaciones desarrolladas por NIST e ISO/IEC, National Institute of Standards and Technology, y International Organization for Standardization/International Electrotechnical Commission, respectivamente.





SUPERINTENDENCIA

DE BANCA, SEGUROS Y AFP

República del Perú

Anexo 2. Aplicaciones web y móviles en producción que ofrecen alguna acción que requiera autenticación reforzada, según Resolución SBS

N° 504-2022

Información al 31 de julio de 2022

Aplicativo Web o Móvil	Denominación comercial de aplicación web o móvil en producción	Cantidad de usuarios registrados	Cantidad de usuario activos	Factores utilizados para el enrolamiento	Factores utilizados para la autenticación reforzada

Los Laureles N° 214 - Lima 27 - Perú Telf.: (511) 6309000 Fax: (511) 6309239

